

Application e-commerce - Exigences métier

Table of Contents

1. Objectif et périmètre	1
2. Acteurs concernés	2
3. Besoins de l'Administrateur	2
4. Besoins du Vendeur	3
5. Besoins de l'Acheteur	5
6. Contraintes opérationnelles	7
7. Matrice de traçabilité	7
8. Exigences de sécurité	9
8.1. Authentification et gestion des accès	9
8.2. Mots de passe	10
8.3. Stockage des mots de passe	11
8.4. Sécurité des communications	12
8.5. Sécurité applicative	12
8.6. Journalisation et surveillance	13
9. Exigences RGPD	13
9.1. Minimisation et finalité (Art. 5)	13
9.2. Droits des personnes concernées (Art. 15–20)	14
9.3. Durées de conservation (Art. 5e)	14
9.4. Sous-traitants (Art. 28)	15
9.5. Protection dès la conception (Art. 25)	15
9.6. Consentement marketing (Art. 6 §1a, Art. 7)	16

1. Objectif et périmètre

Ce document recense les **besoins opérationnels** de l'application e-commerce, c'est-à-dire ce que les acteurs ont besoin de pouvoir faire dans leur contexte métier réel, indépendamment de tout système à construire. Ce document inclut également les exigences de sécurité issues des recommandations de l'ANSSI, ainsi que les exigences réglementaires de la loi RGPD.

L'Analyse du Besoin Opérationnel (OA — voir [01-operational-analysis/oa.adoc](#)) dérive de ces besoins. Ils constituent la référence à satisfaire ; la manière dont le système y répond est documentée aux niveaux SA, LA et PA de l'architecture ARCADIA.

Un besoin opérationnel exprime **la nécessité d'un acteur** (ce qu'il doit pouvoir accomplir dans son activité), non une fonction système.

2. Acteurs concernés

Acteur	Type	Rôle dans l'opération
Administrateur	Acteur principal interne	Gestionnaire des comptes utilisateurs et des transporteurs ; garant de la disponibilité de la plateforme
Vendeur	Acteur principal interne	Exploitant de la boutique : catalogue, stocks, commandes, expéditions, facturation et service client
Acheteur	Acteur principal externe	Client final résidant dans la zone euro : navigation, achat, paiement, suivi et retour
Transporteur	Acteur externe	Prestataire logistique ; prend en charge les colis déposés par le vendeur et assure la livraison dans la zone euro
Prestataire de paiement	Système externe	Autorisation et confirmation des transactions bancaires ; traitement des remboursements
Service de messagerie	Système externe	Acheminement des emails vers les boîtes mail des acteurs (activation, notifications, confirmations)

3. Besoins de l'Administrateur

Identifiant	Besoin	Source OA
BES-ADM-001	L'administrateur a besoin de créer des comptes utilisateurs (acheteurs et vendeurs) sur la plateforme.	UC_A1, Acteurs opérationnels
BES-ADM-002	L'administrateur a besoin de suspendre un compte utilisateur pour en bloquer temporairement l'accès.	UC_A1, Activités administrateur
BES-ADM-003	L'administrateur a besoin de supprimer un compte utilisateur de la plateforme.	UC_A1, Activités administrateur
BES-ADM-004	L'administrateur a besoin de gérer les droits d'accès des utilisateurs à la plateforme.	UC_A1b, Acteurs opérationnels
BES-ADM-005	L'administrateur a besoin d'ajouter des transporteurs disponibles pour les expéditions vers la zone euro.	UC_A2a, Activités administrateur
BES-ADM-006	L'administrateur a besoin de modifier ou supprimer les transporteurs existants.	UC_A2b, Activités administrateur

Identifiant	Besoin	Source OA
BES-ADM-007	L'administrateur a besoin d'activer ou de désactiver le mode maintenance de la boutique, rendant toutes les pages inaccessibles aux utilisateurs non-administrateurs pendant la maintenance.	UC_A3, Activités administrateur



L'administrateur n'a pas accès aux données personnelles des comptes (nom, email, adresse). Cette limitation est intentionnelle et découle du principe de minimisation des données (RGPD Art. 5) et de la protection de la vie privée dès la conception (RGPD Art. 25). Chaque utilisateur gère ses propres données depuis son espace personnel.

4. Besoins du Vendeur

Identifiant	Besoin	Source OA
BES-VND-001	Le vendeur a besoin de mettre à jour ses informations personnelles de compte (nom, adresse, mot de passe, coordonnées).	UC_V0, Activités vendeur
BES-VND-002	Le vendeur a besoin de créer, modifier et supprimer des fiches produits dans le catalogue (photos, descriptions, prix, type de produit, thème/occasion).	UC_V1, Activités vendeur
BES-VND-003	Le vendeur a besoin de suivre les niveaux de stock, d'anticiper les ruptures et d'effectuer les réapprovisionnements.	UC_V2, Activités vendeur
BES-VND-004	Le vendeur a besoin de prendre en charge les commandes reçues, de vérifier la disponibilité du stock et de préparer les colis.	UC_V3, Activités vendeur
BES-VND-005	Le vendeur a besoin de marquer une commande comme expédiée en saisissant le numéro de suivi obtenu sur le reçu du transporteur lors du dépôt physique du colis.	UC_V4, Activités vendeur, Diagramme d'activité
BES-VND-006	Le vendeur a besoin de confirmer manuellement dans la boutique la réception effective d'un virement bancaire afin de déclencher la prise en charge de la commande correspondante.	Activités vendeur, COP-02, Diagramme de séquence
BES-VND-008	Le vendeur a besoin d'accepter ou de refuser une demande d'annulation soumise par un acheteur après expédition, en choisissant entre deux modalités : avec condition de renvoi du colis ou sans condition de renvoi.	UC_V8, Activités vendeur, Diagramme d'activité

Identifiant	Besoin	Source OA
BES-VND-009	Le vendeur a besoin d'émettre un virement bancaire inverse vers l'acheteur et de confirmer son émission dans la boutique lorsqu'une commande réglée par virement est annulée.	Activités vendeur, Diagramme d'activité
BES-VND-010	Le vendeur a besoin de consulter des rapports de ventes (chiffre d'affaires, produits les plus vendus, statistiques commerciales).	UC_V6, Activités vendeur
BES-VND-011	Le vendeur a besoin de créer, modifier, réordonner et supprimer des annonces défilantes affichées sur la page d'accueil de la boutique. Il doit pouvoir associer à chaque annonce une image en orientation portrait ou paysage : la boutique détecte automatiquement l'orientation à partir des dimensions de l'image et la catégorise sans intervention manuelle.	UC_V9, Activités vendeur
BES-VND-012	Le vendeur a besoin d'importer en masse des produits dans le catalogue partagé depuis un fichier CSV : créer de nouvelles fiches produits, ou mettre à jour uniquement le stock de produits existants, afin de gagner du temps lors d'une initialisation, d'un renouvellement de l'offre ou d'un réapprovisionnement en masse.	UC_V1, Activités vendeur
BES-VND-013	Le vendeur a besoin d'exporter l'ensemble du catalogue produits partagé au format CSV afin de le consulter hors ligne, le partager ou le réimporter ultérieurement pour mettre à jour les stocks en masse.	UC_V1, Activités vendeur
BES-VND-014	Le vendeur a besoin de mettre à jour les niveaux de stock de plusieurs produits simultanément depuis une vue liste, sans avoir à ouvrir chaque fiche produit individuellement.	UC_V2, Activités vendeur
BES-VND-015	Le vendeur a besoin de personnaliser l'identité visuelle de sa boutique en configurant l'ensemble de ses visuels et de ses couleurs. Chaque visuel peut être téléversé, remplacé ou supprimé ; la suppression restaure l'état par défaut. Les couleurs (accentuation et fond) sont personnalisables via un sélecteur hexadécimal et réinitialisables à la valeur par défaut. Toute modification est répercutée immédiatement sur le portail acheteur, sans interruption de service. Les visuels des annonces défilantes du carrousel sont gérés via BES-VND-011 .	UC_V11, Activités vendeur
BES-VND-016	Le vendeur a besoin de classer chaque produit selon deux axes de catégorisation indépendants : le type de produit (ex. carte, poster, affiche...) et le thème ou occasion (ex. paysage, portrait, naissance, vacances...). Pour chaque axe, il doit pouvoir saisir librement une valeur ou sélectionner une valeur déjà utilisée dans le catalogue via une liste déroulante combinée (combobox).	UC_V1, Activités vendeur

Identifiant	Besoin	Source OA
BES-VND-017	Le vendeur a besoin d'envoyer des emails promotionnels (offres spéciales, nouveaux produits, événements) aux acheteurs ayant explicitement consenti à recevoir ce type de communication. Il doit pouvoir rédiger le contenu de la campagne et déclencher l'envoi vers la liste des acheteurs consentants. L'envoi est conditionné à l'existence d'au moins un acheteur consentant.	UC_V12, Activités vendeur, RGD-CONS-001, RGD-CONS-003

5. Besoins de l'Acheteur

Identifiant	Besoin	Source OA
BES-ACH-001	L'acheteur a besoin de créer un compte sur la boutique en saisissant ses informations personnelles.	UC_B0, Activités acheteur
BES-ACH-002	L'acheteur a besoin d'activer son compte en consultant sa boîte mail et en cliquant sur le lien d'activation qui lui est adressé après inscription, avant de pouvoir utiliser la boutique.	UC_B0B, Activités acheteur, COp-04
BES-ACH-003	L'acheteur a besoin de s'authentifier pour accéder aux fonctionnalités d'achat (panier, commande, suivi, annulation).	UC_B_AUTH, Activités acheteur
BES-ACH-004	L'acheteur a besoin de mettre à jour ses informations personnelles (adresse de livraison, mot de passe, coordonnées).	UC_B_ACC, Activités acheteur
BES-ACH-005	L'acheteur a besoin de parcourir, rechercher et filtrer les produits disponibles dans le catalogue. Les critères de filtrage disponibles sont : recherche textuelle (nom), type de produit et thème/occasion.	UC_B1, Activités acheteur
BES-ACH-006	L'acheteur a besoin de gérer son panier : ajouter des produits, modifier les quantités, retirer des articles.	UC_B2, Activités acheteur
BES-ACH-007	L'acheteur a besoin que son panier soit automatiquement sauvegardé lorsqu'il quitte la boutique et restauré tel quel à la reconnexion.	UC_B2B, Activités acheteur, COp-03
BES-ACH-008	L'acheteur a besoin de passer une commande en saisissant une adresse de livraison dans un pays de la zone euro et en choisissant le mode de livraison disponible.	UC_B3, UC_B4B, Activités acheteur

Identifiant	Besoin	Source OA
BES-ACH-009	L'acheteur a besoin de régler ses commandes par carte bancaire (autorisation immédiate) ou par virement bancaire (la commande reste en attente de confirmation manuelle du vendeur jusqu'à réception effective des fonds).	UC_B4, Activités acheteur, COp-02
BES-ACH-010	L'acheteur a besoin de suivre l'état d'expédition de sa commande et de consulter le numéro de suivi de son colis.	UC_B5, Activités acheteur
BES-ACH-011	L'acheteur a besoin d'annuler en autonomie depuis son espace compte une commande dont le colis n'a pas encore été remis au transporteur, avec déclenchement automatique du remboursement sans intervention du vendeur.	UC_B6, Activités acheteur, Diagramme d'activité
BES-ACH-012	L'acheteur a besoin de demander l'annulation d'une commande déjà expédiée depuis son espace commandes, en saisissant un message expliquant la situation au vendeur. La commande passe en état « demande d'annulation ». L'acheteur doit être notifié de la décision du vendeur (acceptation sans renvoi, acceptation avec renvoi du colis, ou refus).	UC_B7, Activités acheteur
BES-ACH-013	L'acheteur a besoin de gérer un carnet d'adresses de livraison : ajouter plusieurs adresses, les modifier, les supprimer et en désigner une par défaut, afin de sélectionner rapidement une adresse existante lors du passage d'une commande. Chaque adresse comporte un nom de destinataire qui peut différer du nom du compte acheteur (ex. livraison à un tiers ou envoi en cadeau).	UC_B_ACC, Activités acheteur
BES-ACH-014	L'acheteur a besoin que les annonces défilantes affichées sur la page d'accueil respectent l'orientation naturelle de chaque image (portrait affiché en format réduit centré, paysage affiché en pleine largeur), afin de garantir une expérience visuelle optimale sans distorsion.	UC_V9, Activités acheteur
BES-ACH-015	L'acheteur a besoin d'être alerté par email lorsqu'un produit actuellement indisponible redevient en stock, afin de pouvoir l'acheter sans avoir à surveiller régulièrement la boutique. L'abonnement à l'alerte doit être possible depuis la fiche produit, et consultable ou annulable depuis son espace compte.	UC_B1, Activités acheteur
BES-ACH-016	L'acheteur a besoin de donner ou retirer son consentement aux emails promotionnels du vendeur, à l'inscription (case non pré-cochée) et depuis son espace compte. Le retrait de consentement prend effet immédiatement et ne conditionne pas l'accès aux fonctionnalités de la boutique.	UC_B_ACC, Activités acheteur, RGPD-CONS-002

6. Contraintes opérationnelles

Les contraintes suivantes s'imposent indépendamment des acteurs et de toute décision d'architecture. Elles proviennent du contexte d'usage réel.

Identifiant	Contrainte	Description
COp-01	Interface responsive (PC / smartphone)	Les acteurs interagissent avec la boutique depuis des environnements variés. L'acheteur utilise principalement un smartphone ; le vendeur et l'administrateur opèrent depuis un ordinateur. L'interface doit s'adapter à toutes ces résolutions sans dégradation de l'expérience utilisateur.
COp-02	Modes de paiement acceptés	L'acheteur doit pouvoir régler par carte bancaire (traitement automatique via le prestataire externe) ou par virement bancaire (la commande reste en attente de confirmation manuelle du vendeur jusqu'à réception effective des fonds).
COp-03	Persistance du panier entre sessions	Le panier d'un acheteur authentifié est automatiquement sauvegardé sur son compte et restauré tel quel à la reconnexion.
COp-04	Activation de compte par email	Le compte d'un acheteur n'est accessible qu'après activation via un lien reçu par email suite à l'inscription.
COp-08	Interface multilingue (FR / EN / ES)	Les trois interfaces utilisateur (portail acheteur, espace vendeur, console d'administration) sont disponibles en français (langue par défaut), en anglais et en espagnol . Chaque compte dispose d'une préférence de langue de notification indépendante de la langue de navigation. La sélection de langue est accessible depuis toutes les pages via un sélecteur visible dans l'en-tête. (CS-10 / FS-A06)

7. Matrice de traçabilité

Le tableau ci-dessous relie chaque besoin opérationnel aux activités et cas d'utilisation de l'OA dont il est issu.

Besoin	Acteur	Origine OA (activité / cas d'utilisation)
BES-ADM-001	Administrateur	UC_A1 — Créer / suspendre / supprimer un compte
BES-ADM-002	Administrateur	UC_A1 — Activité « Gérer les comptes utilisateurs »
BES-ADM-003	Administrateur	UC_A1 — Activité « Gérer les comptes utilisateurs »
BES-ADM-004	Administrateur	UC_A1b — Gérer les droits d'accès
BES-ADM-005	Administrateur	UC_A2a — Ajouter un transporteur
BES-ADM-006	Administrateur	UC_A2b — Modifier / supprimer un transporteur
BES-ADM-007	Administrateur	UC_A3 — Basculer en mode maintenance
BES-VND-001	Vendeur	UC_V0 — Mettre à jour son compte
BES-VND-002	Vendeur	UC_V1 — Gérer le catalogue produits
BES-VND-003	Vendeur	UC_V2 — Gérer les stocks
BES-VND-004	Vendeur	UC_V3 — Traiter les commandes reçues
BES-VND-005	Vendeur	UC_V4 — Expédier vers la zone euro
BES-VND-006	Vendeur	COp-02 — Confirmer réception virement bancaire
BES-VND-008	Vendeur	UC_V8 — Traiter un retour après expédition
BES-VND-009	Vendeur	Activité « Émettre un virement inverse de remboursement »
BES-VND-010	Vendeur	UC_V6 — Consulter les rapports de ventes
BES-VND-011	Vendeur	UC_V9 — Gérer les annonces défilantes
BES-VND-012	Vendeur	UC_V1 — Import CSV catalogue (création + mise à jour stock par id)
BES-VND-013	Vendeur	UC_V1 — Export CSV catalogue
BES-VND-014	Vendeur	UC_V2 — Mise à jour en masse des stocks
BES-VND-015	Vendeur	UC_V11 — Personnaliser l'identité visuelle
BES-VND-016	Vendeur	UC_V1 — Classer les produits par type et thème/occasion
BES-VND-017	Vendeur	UC_V12 — Envoyer des emails promotionnels aux acheteurs consentants
BES-ACH-001	Acheteur	UC_B0 — S'inscrire
BES-ACH-002	Acheteur	UC_B0B — Activer son compte via email ; COp-04
BES-ACH-003	Acheteur	UC_B_AUTH — S'authentifier
BES-ACH-004	Acheteur	UC_B_ACC — Mettre à jour son compte

Besoin	Acteur	Origine OA (activité / cas d'utilisation)
BES-ACH-005	Acheteur	UC_B1 — Parcourir le catalogue
BES-ACH-006	Acheteur	UC_B2 — Gérer le panier
BES-ACH-007	Acheteur	UC_B2B — Sauvegarder / restaurer le panier ; COp-03
BES-ACH-008	Acheteur	UC_B3, UC_B4B — Passer une commande
BES-ACH-009	Acheteur	UC_B4 — Effectuer un paiement ; COp-02
BES-ACH-010	Acheteur	UC_B5 — Suivre la livraison
BES-ACH-011	Acheteur	UC_B6 — Annuler une commande (avant expédition)
BES-ACH-012	Acheteur	UC_B7 — Demander une annulation après expédition
BES-ACH-013	Acheteur	UC_B_ACC — Gérer le carnet d'adresses de livraison
BES-ACH-014	Acheteur	UC_V9 — Affichage des annonces adapté à l'orientation des images
BES-ACH-015	Acheteur	UC_B1 — S'abonner à une alerte de remise en stock
BES-ACH-016	Acheteur	UC_B_ACC — Gérer le consentement aux emails promotionnels du vendeur ; RGPD-CONS-002

8. Exigences de sécurité

Les exigences suivantes sont issues des guides et recommandations publiés par l'ANSSI (Agence nationale de la sécurité des systèmes d'information). Elles s'appliquent à la plateforme indépendamment des besoins métier.

Sources principales : [ANSSI-BP-076](#) et [ANSSI-PG-078 v2.0](#) — Recommandations relatives à l'authentification multifacteur et aux mots de passe.

8.1. Authentification et gestion des accès

Référence : ANSSI-BP-076 / ANSSI-PG-078 v2.0

Identifiant	Exigence	Réf. ANSSI	Acteurs
SEC-AUTH-001	Les mots de passe des comptes doivent comporter au minimum 12 caractères et combiner majuscules, minuscules, chiffres et caractères spéciaux.	PG-078 R21, R23	Tous

Identifiant	Exigence	Réf. ANSSI	Acteurs
SEC-AUTH-002	Les mots de passe doivent être stockés sous forme hachée avec un algorithme résistant (BCrypt, Argon2id ou scrypt) ; le stockage en clair ou en MD5/SHA-1 est interdit.	BP-076 §3.3 / PG-078 R28, R29	—
SEC-AUTH-003	Les tentatives d'authentification échouées répétées doivent déclencher un mécanisme de protection (temporisation progressive, verrouillage temporaire ou CAPTCHA) afin de prévenir les attaques par force brute.	BP-076 §3.2 / PG-078 R10	Tous
SEC-AUTH-004	Les sessions authentifiées doivent expirer après une période d'inactivité de 30 minutes maximum. La déconnexion explicite doit invalider immédiatement le jeton de session côté serveur. Les cookies de session doivent avoir une durée de vie limitée.	BP-076 §4.1 / PG-078 R12	Tous
SEC-AUTH-005	Les droits d'accès doivent respecter le principe du moindre privilège : chaque rôle (administrateur, vendeur, acheteur) ne doit accéder qu'aux ressources strictement nécessaires à ses activités.	BP-076 §2.1	Tous
SEC-AUTH-006	En cas d'échec d'authentification, le système ne doit pas indiquer quel facteur (identifiant ou mot de passe) a conduit à l'échec. Un message générique uniforme doit être retourné.	PG-078 R14	Tous
SEC-AUTH-007	L'authentification multifacteur (MFA) doit être proposée pour les comptes Vendeur et Administrateur.	PG-078 R1	Vendeur, Administrateur
SEC-AUTH-008	Le SMS ne doit pas être utilisé comme canal de réception d'un facteur d'authentification (vulnérabilité SIM-swap et interception réseau).	PG-078 R8	Tous

8.2. Mots de passe

Référence : ANSSI-PG-078 v2.0

Identifiant	Exigence	Réf. ANSSI	Acteurs
SEC-PWD-001	Aucune longueur maximale ne doit être imposée sur les mots de passe, afin de permettre l'utilisation de phrases de passe longues.	PG-078 R22	Tous

Identifiant	Exigence	Réf. ANSSI	Acteurs
SEC-PWD-002	La robustesse du mot de passe doit être contrôlée automatiquement à la création et au renouvellement. Les mots de passe figurant dans des listes de mots de passe compromis (ex. HaveIBeenPwned) doivent être rejetés.	PG-078 R27	Tous
SEC-PWD-003	Aucune expiration automatique de mot de passe ne doit être imposée aux comptes Acheteur (sensibilité non élevée).	PG-078 R24	Acheteur
SEC-PWD-004	Un délai d'expiration doit être imposé sur les mots de passe des comptes Administrateur (entre 1 et 3 ans).	PG-078 R25	Administrateur
SEC-PWD-005	En cas de compromission suspectée ou avérée, tous les mots de passe concernés doivent être révoqués dans la journée. Les comptes dont le mot de passe n'a pas été renouvelé doivent être désactivés.	PG-078 R26	Tous
SEC-PWD-006	Une méthode de recouvrement d'accès doit être proposée sous forme de lien de réinitialisation temporaire et à usage unique. Le mot de passe ne doit jamais être transmis en clair par quelque canal que ce soit.	PG-078 R30	Tous

8.3. Stockage des mots de passe

Référence : ANSSI-PG-078 v2.0

Identifiant	Exigence	Réf. ANSSI	Acteurs
SEC-STORE-001	Les mots de passe ne doivent jamais être stockés en clair. Seules leurs empreintes cryptographiques doivent être conservées.	PG-078 R28, R29	—
SEC-STORE-002	Un sel aléatoire d'au moins 128 bits, unique par compte, doit être utilisé lors du calcul de l'empreinte du mot de passe.	PG-078 R28	—
SEC-STORE-003	Les empreintes doivent être calculées avec une fonction de dérivation à coût mémoire élevé : Argon2 ou scrypt en priorité, BCrypt en alternative acceptable.	PG-078 R29, R29-	—

Identifiant	Exigence	Réf. ANSSI	Acteurs
SEC-STORE-004	L'accès à la base de données contenant les empreintes de mots de passe doit être protégé en confidentialité et en intégrité (accès réseau restreint, chiffrement des colonnes sensibles).	PG-078 R13	—

8.4. Sécurité des communications

Référence : [ANSSI-BP-113 — Recommandations de sécurité relatives à TLS](#)

Identifiant	Exigence	Référence ANSSI
SEC-TLS-001	Toutes les communications entre les clients (navigateurs, API) et la plateforme doivent être chiffrées via TLS 1.2 au minimum ; TLS 1.3 est recommandé. Les versions SSLv3, TLS 1.0 et TLS 1.1 sont interdites.	ANSSI-BP-113 §3.1
SEC-TLS-002	Les certificats TLS doivent être émis par une autorité de certification reconnue, valides et renouvelés avant expiration.	ANSSI-BP-113 §4.1
SEC-TLS-003	Le cookie de session doit porter les attributs Secure , HttpOnly et SameSite=Strict afin d'empêcher son interception ou sa lecture par des scripts.	ANSSI-BP-113 §5.2

8.5. Sécurité applicative

Référence : [ANSSI — Recommandations pour la sécurisation des sites web](#)

Identifiant	Exigence	Référence ANSSI
SEC-APP-001	Toutes les données saisies par les utilisateurs doivent être validées et assainies côté serveur avant tout traitement ou persistance, afin de prévenir les injections (SQL, commandes, LDAP) et les attaques XSS.	ANSSI Web §3.1
SEC-APP-002	Les formulaires et requêtes d'état (commande, paiement, modification de compte) doivent être protégés contre les attaques CSRF par jeton anti-forgery ou vérification de l'en-tête Origin .	ANSSI Web §3.3
SEC-APP-003	Les messages d'erreur retournés aux utilisateurs ne doivent pas exposer d'informations techniques internes (traces de pile, noms de tables, chemins de fichiers).	ANSSI Web §4.2
SEC-APP-004	Les composants tiers (bibliothèques, frameworks, dépendances) doivent être maintenus à jour et exempts de vulnérabilités critiques connues (CVE de score CVSS ≥ 7.0).	ANSSI Web §5.1

Identifiant	Exigence	Référence ANSSI
SEC-APP-005	Une politique de sécurité du contenu (Content Security Policy) doit être définie et appliquée via l'en-tête HTTP Content-Security-Policy pour restreindre les sources de scripts et ressources chargées par le navigateur.	ANSSI Web §3.4

8.6. Journalisation et surveillance

Référence : ANSSI — Recommandations de sécurité pour l'administration des systèmes d'information / ANSSI-PG-078 v2.0

Identifiant	Exigence	Réf. ANSSI	Acteurs
SEC-LOG-001	Les événements liés à l'authentification doivent être journalisés avec horodatage, identifiant utilisateur et adresse IP : création de compte, tentatives réussies et échouées, demandes de renouvellement de mot de passe, révocations, actions d'administration, transactions de paiement.	ANSSI Admin §4.1 / PG-078 R9	Tous
SEC-LOG-002	Les journaux d'authentification et de sécurité doivent permettre la détection de comportements anormaux (tentatives répétées, connexions inhabituelles) et faciliter les investigations en cas d'incident.	ANSSI Admin §4.2 / PG-078	Tous
SEC-LOG-003	Les journaux de sécurité doivent être conservés pendant une durée minimale de 12 mois et protégés contre toute modification ou suppression non autorisée.	ANSSI Admin §4.2	—
SEC-LOG-004	Les accès aux journaux doivent être restreints aux seuls administrateurs de la plateforme.	ANSSI Admin §4.3	Administrateur

9. Exigences RGPD

Les exigences suivantes découlent du Règlement Général sur la Protection des Données (RGPD — Règlement UE 2016/679). Elles s'appliquent à toutes les données à caractère personnel traitées par la plateforme.

9.1. Minimisation et finalité (Art. 5)

Identifiant	Exigence	Article RGPD
RGPD-MIN-001	Seules les données strictement nécessaires à l'exécution du service doivent être collectées : identité (nom, prénom), email, adresse de livraison dans la zone euro (incluant le nom du destinataire, qui peut différer du nom du compte), préférence de langue, historique de commandes. Aucune donnée non justifiée par une finalité explicite ne doit être stockée.	Art. 5 §1c
RGPD-MIN-002	Les données bancaires de l'acheteur (numéro de carte, IBAN) ne sont jamais stockées en clair sur la plateforme. Le numéro de carte est délégué intégralement à Stripe (PCI-DSS Level 1). L'IBAN fourni lors d'une demande de remboursement par virement est stocké chiffré (pgcrypto) et purgé dès clôture du remboursement.	Art. 5 §1c, Art. 25
RGPD-MIN-003	L'administrateur n'a pas accès aux données personnelles des comptes (nom, email, adresse). Son périmètre se limite à la gestion des accès (création, suspension, suppression, rôles) et à la langue de notification. Cette restriction est intentionnelle (privacy by design).	Art. 5 §1c, Art. 25

9.2. Droits des personnes concernées (Art. 15–20)

Identifiant	Exigence	Article RGPD
RGPD-DRT-001	Chaque utilisateur (acheteur, vendeur) doit pouvoir consulter et modifier ses données personnelles depuis son espace compte (nom, adresse, mot de passe, langue de notification).	Art. 16 — Rectification
RGPD-DRT-002	L'acheteur doit pouvoir demander la suppression de son compte. La suppression déclenche l'anonymisation des données personnelles identifiantes (nom, prénom, email remplacés par des valeurs neutres). L'historique des commandes est conservé sous forme anonymisée pour satisfaire les obligations légales et comptables (durée légale de conservation des documents commerciaux : 10 ans).	Art. 17 — Effacement
RGPD-DRT-003	L'acheteur doit pouvoir exporter ses données personnelles dans un format structuré et lisible (JSON ou CSV) : informations de compte, carnet d'adresses de livraison, historique des commandes.	Art. 20 — Portabilité

9.3. Durées de conservation (Art. 5e)

Identifiant	Exigence	Article RGPD
RGPD-RET-001	Les données personnelles des comptes actifs sont conservées tant que le compte est actif. Après suppression du compte, les données identifiantes sont anonymisées dans un délai de 30 jours.	Art. 5 §1e

Identifiant	Exigence	Article RGPD
RGPD-RET-002	Les données de commandes (lignes, montants, statuts) sont conservées sous forme anonymisée pendant 10 ans à compter de la date de la commande, afin de respecter les obligations légales comptables et fiscales.	Art. 5 §1e, Art. 17 §3b
RGPD-RET-003	Les journaux de sécurité et d'audit sont conservés 12 mois minimum et 13 mois maximum, puis purgés automatiquement. Les enregistrements relatifs à un compte supprimé sont anonymisés (identifiant utilisateur remplacé) dans le même délai de 30 jours que les données du compte.	Art. 5 §1e

9.4. Sous-traitants (Art. 28)

Identifiant	Exigence	Article RGPD
RGPD-SUB-001	Stripe (prestataire de paiement) est sous-traitant au sens du RGPD. Un accord de traitement des données (DPA) doit être en vigueur avant toute mise en production. Stripe est certifié PCI-DSS Level 1 et traite les données de carte bancaire en lieu et place de la plateforme.	Art. 28
RGPD-SUB-002	SendGrid (service de messagerie transactionnelle) est sous-traitant au sens du RGPD. Un DPA doit être en vigueur. Les emails transactionnels transmis à SendGrid contiennent uniquement les données nécessaires à leur acheminement (adresse email destinataire, contenu de notification).	Art. 28
RGPD-SUB-003	Aucun sous-traitant ne doit être ajouté ou substitué sans vérification préalable de sa conformité RGPD et signature d'un DPA.	Art. 28 §2

9.5. Protection dès la conception (Art. 25)

Identifiant	Exigence	Article RGPD
RGPD-PBD-001	L'architecture applique le principe de privacy by design : cloisonnement des rôles (acheteur, vendeur, administrateur), chiffrement des colonnes sensibles en base (pgcrypto), suppression logique avec anonymisation planifiée, accès administrateur limité aux métadonnées de gestion.	Art. 25 §1
RGPD-PBD-002	Par défaut, aucune donnée personnelle n'est partagée avec des tiers à des fins de profilage ou de marketing. Les emails envoyés sont exclusivement transactionnels (activation de compte, confirmation de commande, notification d'expédition, remboursement). Toute extension à des emails marketing nécessite un consentement explicite et une exigence dédiée.	Art. 25 §2, Art. 6 §1a

Identifiant	Exigence	Article RGPD
RGPD-PBD-003	Conditionnel — à implémenter uniquement si des cookies non essentiels sont introduits (analytics, tracking, pub, chat). Tant que la plateforme n'utilise que des cookies strictement nécessaires (session, authentification JWT, panier), aucun bandeau de consentement n'est requis. Si un cookie non essentiel est ajouté, la plateforme doit : (1) afficher un bandeau de consentement conforme CNIL avant tout dépôt de cookie non essentiel, (2) publier une politique de confidentialité listant les cookies, leurs finalités et durées de conservation, (3) permettre le retrait du consentement aussi facilement qu'il a été donné.	ePrivacy (dir. 2002/58/CE), Art. 6 §1a, Art. 7

9.6. Consentement marketing (Art. 6 §1a, Art. 7)

Identifiant	Exigence	Article RGPD
RGPD-CONS-001	La plateforme ne peut transmettre l'adresse email d'un acheteur à un outil de mailing externe à des fins de campagne commerciale qu'après obtention d'un consentement explicite, libre, éclairé et non pré-coché (opt-in) de l'acheteur. Ce consentement est distinct du consentement aux conditions générales de vente.	Art. 6 §1a, Art. 7 §2
RGPD-CONS-002	L'acheteur doit pouvoir donner ou retirer son consentement marketing à tout moment : à l'inscription (case à cocher non pré-cochée) et depuis son espace compte. Le retrait de consentement prend effet immédiatement et ne conditionne pas l'accès aux fonctionnalités de la boutique.	Art. 7 §3
RGPD-CONS-003	Le consentement est horodaté à l'obtention et au retrait éventuel. Seuls les acheteurs ayant donné leur consentement peuvent être inclus dans un export à des fins de campagne.	Art. 5 §2
RGPD-CONS-004	L'outil de mailing externe (Brevo, Mailchimp, SendGrid Marketing...) utilisé pour les campagnes est sous-traitant au sens du RGPD. Un DPA doit être en vigueur avant tout export de liste. La liste transmise ne contient que les adresses des acheteurs consentants.	Art. 28